LifeCharter Command Suite: Security and Privacy Summary

Prepared October 2026 for the Investor Brief data room. It states what is in place today and what is not.

How the system is built

- The web application runs on Vercel. Data is held in Supabase (Postgres). Payments run through Stripe, email through Resend and live events through Zoom.
- Each client's AI assistant uses that account's own OpenAI key. The house key is a fallback for the founder's own account only.

Separation of client data

- Row-level security is enabled on the database tables. Client data is reached through the Suite's authenticated server routes, scoped to the signed-in account.
- Founder-only sections are limited to the founder's account, and that check is enforced on the server as well as in the page.

Passwords and sensitive logins

- The Logins and Passwords vault stores passwords and notes encrypted in Supabase Vault. Lists never contain secrets.
- A password is decrypted only on the server, one item at a time, after the person re-enters their Suite password. The unlock is a signed 15-minute session, attempts are rate limited, and every reveal is written to an audit log.

Payments

- Card details are entered on Stripe-hosted pages. The Suite does not store card numbers. Stripe webhooks are verified by signature.

Control over automated actions

- The AI assistant shows a preview and acts only after the client approves. Email written by the assistant is draft-only.
- Clients send email from their own sending account, so one client's sending reputation is separate from another's.
- Scheduled background jobs authenticate with a shared secret that is configured in production.

Quality

- Automated tests run on every change, and a page-by-page checklist covers 112 pages.

Privacy

- The Privacy Policy, Terms of Sale, Year-1 Commitment Acknowledgment and Community Guidelines are published. The Privacy Policy includes a data-retention section.
- The Terms of Sale state that the client retains all rights to the business data they enter into the Suite.

Not yet in place, stated plainly

- No formal SOC 2 report; it has not been started.
- Google's restricted-scope security assessment has not been completed. Send-only Gmail access was chosen to avoid it for now.
- Email deliverability on Microsoft inboxes is being worked through.
- A third-party security review is planned as client revenue allows.

This summary describes the application as built. It is not an audit or a certification.